

Rapport d'Audit Complet - API FriPay

Date : 19 aout 2026 | **Scope :** Tous les microservices + freipay-common
Base : PostgreSQL 17 | **Framework :** Laravel 13 + Sanctum | **PHP :** ^8.3
Corrections appliquees : 13/19 Problemes traitees (4 critiques + 5 eleves + 4 moyens)

1. Resume Executif

4/4 CRITIQUES CORRIGES	5/7 ELEVES CORRIGES	4/7 MOYENS CORRIGES	0/5 BAS (A FAIRE)
---------------------------	------------------------	------------------------	----------------------

Categorie	Critique	Elevee	Moyenne	Basse	Total
Securite	2/2 OK	2/3 OK	1/1 OK	0	5/6
Code	1/1 OK	1/1 OK	0	0	2/2
Architecture	0	1/2 OK	1/3 OK	0/2	2/7
Base de donnees	1/1 OK	1/1 OK	2/3 OK	0/1	4/6
Total	4/4	5/7	4/7	0/5	13/19

2. Architecture

Service	Port	Auth	Role
fripay-gateway	8080	-	Rate limiting, circuit breaker, routage
fripay-users	8000	Sanctum	Inscription, profil, contacts
fripay-payments	8001	Sanctum	Transferts, webhooks, QR codes
fripay-admin	8002	Sanctum staff	Back-office, RBAC, corridors

3. Critiques (4/4 CORRIGES)

CRITIQUE C1 - Middleware IdempotencyMiddleware manquant

Fichier freipay-users/bootstrap/app.php importait un middleware inexistant. Erreur 500 sur POST /users/me/accounts.

Correction : CORRIGE Fichier cree.

CRITIQUE C2 - Hashes bcrypt exposes dans le SQL dump

Le dump contenait des hashes bcrypt de mots de passe admin et OTP.

Correction : CORRIGE Remplaces par HASH_ANONYMIZED_001/002.

CRITIQUE C3 - CORS wildcard * dans le gateway

Le gateway autorisait * pour les origines CORS. Risque CSRF et vol de tokens.

Correction : CORRIGE Origines restreintes via FRIPAY_CORS_ORIGINS.

CRITIQUE C4 - Injection SQL dans TransferController.sort

Le parametre sort etait utilise directement dans orderBy() sans validation.

Correction : CORRIGE Whitelist : initiated_at, amount, status, completed_at.

4. Eleves (5/7 CORRIGES)

ELEVEE E1 - RateLimiter nettoyage 1% chance

Correction : CORRIGE Nettoyage horodate (1x/min).

ELEVEE E2 - refreshTokens() O(n)

Correction : CORRIGE Lookup par empreinte token (sha256) + index compose.

ELEVEE E3 - recipient_phone non valide

Correction : DEJA CORRIGE Regex deja presente.

ELEVEE E4 - Webhooks sans anti-rejeu

Correction : CORRIGE Detection de doublons ajoutée.

ELEVEE E5 - Circuit breaker half_open lent

Correction : CORRIGE Batch de test (3 req) en half_open.

ELEVEE E6 - CorridorController sans audit

Correction : CORRIGE Audit previous + changes.

ELEVEE E7 - Injection SQL (meme que C4)

Correction : CORRIGE Voir C4.

5. Moyens (4/7 CORRIGES)

MOYENNE M1 - CORS allowed_methods: *

Correction : CORRIGE Restreint a GET, POST, PUT, DELETE, OPTIONS dans les 3 services + gateway.

MOYENNE M2 - Logging non structure

Statut : En attente - decision agregateur de logs.

MOYENNE M3 - Webhooks sans rate limiting

Correction : CORRIGE Rate limiter webhook (100/min/IP) + throttle middleware.

MOYENNE M4 - Rate limiter sur disque

Statut : En attente - migration Redis.

MOYENNE M5 - StaffController.store() sans audit

Correction : CORRIGE AuditLog 'staff.created' ajoutée.

MOYENNE M6 - Namespace App\ dans common

Statut : En attente - breaking change.

MOYENNE M7 - min_amount > max_amount possible

Correction : CORRIGE Regle 'gte:min_amount' ajoutée.

6. Bas (0/5 - a traiter)

BASSE B1 - Aucun test PHPUnit

BASSE B2 - Version PHP non verifiee

BASSE B3 - Enum non utilise

BASSE B4 - Routes web.php inutiles

BASSE B5 - .env.example incomplet

7. Points Forts

Aspect	Evaluation
Architecture	Microservices bien separes + gateway dedie
Crypto QR	Ed25519 Sodium, cle effacees apres usage
Idempotence	UUID v5 deterministe
Outbox	Backoff exponentiel, verrou atomique
Circuit breaker	CLOSED/OPEN/HALF_OPEN
Rate limiting	Token bucket + throttle Laravel
RBAC	3 roles, 9 permissions
Audit	audit_logs pour actions critiques
Webhooks	HMAC + IP whitelist + anti-rejeu + throttle

8. Plan d'Actions

Prio	Action	Etat
P0	IdempotencyMiddleware	FAIT
P0	Anonymiser hashes dump	FAIT
P0	Restreindre CORS	FAIT
P0	Corriger injection SQL sort	FAIT
P1	Optimiser refreshTokens()	FAIT
P1	Anti-rejeu webhooks	FAIT
P1	Circuit breaker half_open	FAIT
P1	Audit trail corridors	FAIT
P1	Nettoyage RateLimiter	FAIT
P2	CORS methods restriction	FAIT
P2	Throttle webhooks	FAIT
P2	Audit StaffController	FAIT
P2	Validation min/max	FAIT
P2	Logging JSON	En attente
P2	Namespace common	En attente
P2	Migration Redis	En attente
P3	Tests PHPUnit	En attente
P3	.env.example	En attente

9. Fichiers Modifies (19 fichiers)

Fichier	Service	Changement
app/Http/Middleware/IdempotencyMiddleware.php	users	Cree
app/Services/AuthService.php	users	refreshTokens() optimise
app/Models/AuthSession.php	users	Ajout token_fingerprint
database/migrations/2026_08_19_*.php	users	Migration token_fingerprint
fripay_database_dump.sql	root	Hashes anonymises
config/gateway.php	gateway	CORS restraint
public/index.php	gateway	sendCorsHeaders() corrige
src/RateLimiter.php	gateway	Nettoyage horodate
src/CircuitBreaker.php	gateway	Batch test half_open
Http/Controllers/Api/TransferController.php	payments	Whitelist tri SQL
Http/Controllers/Api/WebhookController.php	payments	Anti-rejeu webhooks
Http/Controllers/Api/Admin/CorridorController.php	admin	Audit trail
Http/Controllers/Api/Admin/StaffController.php	admin	Audit creation
Http/Requests/Admin/CorridorRequest.php	admin	Validation min/max
config/cors.php	admin	Methods restreintes
config/cors.php	payments	Methods restreintes
config/cors.php	users	Methods restreintes
app/Providers/AppServiceProvider.php	payments	Rate limiter webhook
routes/api.php	payments	Throttle webhooks

10. Migration

```
cd freipay-users && php artisan migrate
```

11. Config Production

```
FRIPAY_CORS_ORIGINS=https://app.fripay.bj,https://admin.fripay.bj
```